03

IDEASPROPIAS
editorial

Comprensión del entorno de la seguridad informática en una organización

1. Explotación de vulnerabilidades en sistemas Windows obsoletos
2. Active Directory
3. Enumeración básica del entorno AD
4. Enumeración de usuarios de un dominio
5. Explotación ASREProast
6. Enumeración de recursos compartidos desde Kali Linux
7. Uso básico de impacket y Pass-the-Hash

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

1. Enumeración y explotación de vulnerabilidades en sistemas Windows obsoletos

Aplicar técnicas de *hacking* en entornos Windows desactualizados y conocer cómo las vulnerabilidades en estos sistemas pueden ser explotadas para obtener acceso no autorizado es fundamental para entender la importancia crítica de mantener nuestros sistemas **Windows actualizados,** ya que las actualizaciones de seguridad son esenciales para proteger nuestros equipos contra posibles ataques.

Para **identificar la vulnerabilidad** de la máquina objetivo utilizaremos un escaneo de vulnerabilidades con `nmap`.

Explotación de vulnerabilidades en sistemas Windows obsoletos

¿Te gustaría comprender mejor cómo se realiza dicha explotación? Mario Álvarez te enseña cómo hacerlo en este vídeo, con un tiempo de estudio de 07:50.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

2. Active Directory

¿Sabrías definir qué es un entorno de Active Directory (AD) o Directorio Activo?

Qué es un Active Directory

En este vídeo, con un tiempo de estudio de 02:10, Mario Álvarez te explica qué es y cuándo se utiliza un Active Directory.

Llegados a este punto, es momento de comprobar si has comprendido este concepto. ¡Realiza la siguiente actividad!

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

3. Enumeración básica del entorno AD

Al realizar una enumeración de un entorno de Active Directory, encontraremos varios puertos abiertos debido a los diferentes servicios que operan en la red. Sin embargo, es clave centrarse en algunos puertos importantes:

- **Puerto 88:** en él funciona Kerberos, un protocolo de red que proporciona autenticación segura entre los dispositivos del dominio, permitiendo a los usuarios autenticarse de manera centralizada.
- **Puerto 445:** es donde se gestionan los recursos compartidos a través del protocolo SMB *(server message block),* lo que facilita el acceso a archivos y servicios dentro de la red.

Para realizar una enumeración eficiente, existen herramientas como **enum4linux,** que permite automatizar la recolección de información sobre usuarios, grupos, políticas y recursos compartidos de Active Directory. Estas herramientas son valiosas para obtener un panorama claro del entorno, identificando posibles vulnerabilidades o configuraciones erróneas que podrían ser explotadas.

Enumeración básica del entorno AD

¿Quieres saber más sobre esto y conocer en detalle cómo se realiza una enumeración de un entorno de Active Directory? Presta atención a este vídeo de Mario Álvarez, cuyo tiempo de estudio es de 07:37.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

4. Enumeración de usuarios de un dominio

Una vez realizada una enumeración básica del dominio, es crucial enumerar los usuarios disponibles dentro de Active Directory, ya que estos son objetivos clave para posibles ataques de autenticación y escalación de privilegios.

Para esta tarea, herramientas como **kerbrute** son extremadamente útiles, ya que permiten realizar ataques de fuerza bruta o de enumeración de usuarios a través del protocolo Kerberos. Kerbrute ayuda a identificar nombres de usuarios válidos en el dominio, lo que puede ser un primer paso importante en la explotación de vulnerabilidades o en el desarrollo de técnicas más avanzadas para comprometer cuentas y recursos.

Enumeración de usuarios de un dominio

¿Con ganas de descubrir cómo se realiza la enumeración básica de usuarios de un dominio? ¡Mario Álvarez te lo explica en este vídeo, cuyo tiempo de estudio es de 06:13!

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

5. Explotación ASREProast

Una vez que hemos enumerado los usuarios del dominio, es importante verificar si alguno de ellos es vulnerable a un ataque de **AS-REP Roasting** o **ASREPRoast.**

Este tipo de vulnerabilidad ocurre cuando un usuario no tiene habilitada la preautenticación en Kerberos, lo cual es indicado por la herramienta **Kerbrute** con el mensaje «not preauth».

Si encontramos un usuario vulnerable, podemos aprovechar esta situación utilizando la herramienta **Impacket** para solicitar un ticket Kerberos en nombre de ese usuario, sin necesidad de conocer su contraseña. Este ticket contiene información cifrada con la contraseña del usuario, la cual luego podemos intentar crackear utilizando herramientas de fuerza bruta o diccionario para obtener la contraseña en texto claro, facilitando el acceso al dominio con privilegios adicionales.

Cómo efectuar un ataque ASREProast

Ahora bien, ¿te gustaría saber cómo se efectúa un ataque ASREPRoast? ¡Presta atención a este vídeo de Mario Álvarez, cuyo tiempo de estudio es de 06:02!

¿Te atreves a poner en práctica lo aprendido? ¡Realiza la siguiente actividad!

Actividad

Une cada herramienta con su funcionalidad:

Efectúa un ASREPRoast -> Impacket

Crackea el ticket obtenido para ver la contraseña del usuario -> John the Ripper

Indica cuando un usuario no tiene habilitada la preautenticación en Kerberos -> Kerbrute

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

6. Enumeración de recursos compartidos desde Kali Linux

Una vez que hemos verificado si alguno de los usuarios del dominio es vulnerable a un ataque de ASREPRoast y hemos obtenido las credenciales de alguno de ellos, podemos enumerar recursos compartidos dentro del dominio con dichas credenciales.

En el contexto del protocolo SMB *(server message block),* los recursos compartidos son unidades de almacenamiento o impresoras que una máquina pone a disposición de otras máquinas en una red. Estos recursos pueden ser carpetas, archivos, impresoras y otros dispositivos conectados a la red que se pueden compartir entre sistemas para facilitar el acceso y la colaboración.

Cuando se dispone de credenciales válidas para un servidor SMB, se pueden usar herramientas como **smbclient** para enumerar los recursos compartidos en ese servidor. Esta es una herramienta de línea de comandos que proporciona acceso a los recursos compartidos SMB.

Enumeración de recursos compartidos desde Kali Linux

En este vídeo, con un tiempo de estudio de 06:14, Mario Álvarez te explica cómo se realiza la enumeración de recursos compartidos desde Kali Linux.

Consulta

¿Quieres saber más sobre la utilidad de la herramienta smbclient? Pulsa en el siguiente enlace y accede al artículo «Uso de la utilidad smbclient para acceder a un recurso compartido SMB» de Red Hat Documentation.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

7. Uso básico de impacket y pass-the-hash

Una vez que se han obtenido credenciales de un usuario con altos privilegios dentro de un dominio, puedes usar herramientas especializadas para extraer información crítica como los hashes de contraseñas de otros usuarios.

Un ejemplo de estas herramientas es **impacket-secretsdumps** de la suite de herramientas de Impacket, que permite extraer hashes de contraseñas y otros datos sensibles de sistemas Windows. Esta es una herramienta que permite extraer los hashes de contraseñas almacenados en el sistema de una máquina Windows.

Una vez hayamos conseguido *hashes* de usuarios, podemos efectuar un ataque **Pass-the-Hash** (PtH), la cual es una técnica utilizada para autenticar usuarios en sistemas Windows utilizando el hash de la contraseña en lugar de la contraseña en sí. Una vez que hayamos obtenido el hash de la contraseña de un usuario con altos privilegios, como un administrador del dominio, podemos intentar autenticarnos en otros sistemas o servicios utilizando ese hash.

Uso básico de Impacket y pass-the-hash

¿Quieres saber más sobre el uso de Impacket y Pass-the-Hash? Presta atención a este vídeo, cuyo tiempo de estudio es de 05:56. En él Mario Álvarez te explica cómo utilizar dichas herramientas.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Caso práctico: protección contra ataques de tipo Pass-the-Hash

Eres especialista en seguridad y te han solicitado realizar una prueba de penetración en una red corporativa. El objetivo es evaluar la seguridad de la red interna y verificar la robustez de las medidas de protección contra ataques de tipo Pass-the-Hash.

¿Qué tendrías que hacer?

Reflexiona sobre el proceso a seguir y, posteriormente, descubre la solución:

Solución

Primero, debemos conseguir un acceso con un usuario privilegiado dentro del dominio, lo cual nos llevará por varios procesos, donde primero encontraremos usuarios utilizando la herramienta kerbrute. Si vemos algún usuario vulnerable, podremos explotar vulnerabilidades como ASREPRoast, donde obtendremos la contraseña de un usuario en concreto, para más tarde tratar de enumerar el dominio, por ejemplo, mediante el protocolo SMB, detectando recursos compartidos.

Una vez hayamos enumerado los recursos compartidos, es posible que veamos información confidencial como credenciales o archivos de *backup,* que podremos utilizar para autenticarnos con otro usuario.

Una vez seamos un usuario más privilegiado, podremos utilizar Impacket para enumerar los hashes del resto de usuario del dominio y, en caso de ser posible, ya podríamos comprobar si el usuario administrador es vulnerable a un ataque Pass-the-Hash, al utilizar su hash directamente para autenticarnos en lugar de su contraseña.

Caso práctico: investigación de recursos compartidos

Eres estudiante y te encuentras en una práctica de seguridad de redes. Te han asignado la tarea de investigar los recursos compartidos en un sistema utilizando smbclient con el objetivo de verificar si hay información privada o sensible en estos recursos.

Para esta tarea, tienes las credenciales de un usuario con permisos para acceder a los recursos compartidos del sistema. El acceso es: usuario1 y la contraseña es auditoriawindows123.

¿Podrías explicar cómo se realiza dicha investigación?

Reflexiona sobre el proceso a seguir y, posteriormente, descubre la solución:

Solución

Para la enumeración de recursos compartidos en un sistema, primero utiliza smbclient. Esta herramienta permite listar de manera rápida y eficiente todos los recursos compartidos disponibles en un servidor SMB.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

```
smbclient -L //IP_DEL_SERVIDOR -U usuario1
```

Una vez dentro, podemos conectarnos al recurso compartido que estimemos oportuno con el siguiente comando, suponiendo que existe un recurso compartido llamado backup:

```
smbclient //IP_DEL_SERVIDOR/backup -U usuario1
```

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

¿QUÉ HAS APRENDIDO?

A lo largo de este bloque de contenido, has aprendido a:

- Valorar la importancia de mantener un sistema actualizado.
- Trabajar con el entorno Active Directory.
- Usar smbclient para enumerar el protocolo SMB.
- Enumerar usuarios válidos dentro de una red empresarial de Active Directory.
- Realizar el ataque Pass-the-Hash y a conectarte al dominio con Impacket.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

BIBLIOGRAFÍA

- Learn Microsoft (2023). *Introducción a Active Directory Domain Services.* https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview

  Recurso que proporciona una explicación detallada de Active Directory Domain Services (AD DS), destacando su rol en la gestión de identidades y relaciones dentro de redes empresariales.

- Red Hat Documentation (s.f.). *Uso de la utilidad smbclient para acceder a un recurso compartido SMB.* Consultado el 17 de septiembre de 2024. https://docs.redhat.com/es/documentation/red_hat_enterprise_linux/8/html/deploying_different_types_of_servers/assembly_using-the-smbclient-utility-to-access-an-smb-share_assembly_using-samba-as-a-server

  Artículo de Red Hat que explica cómo utilizar la herramienta smbclient para acceder a recursos compartidos SMB en redes que utilizan el protocolo Samba.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

ENLACES DE INTERÉS

- **Cómo acceder a cualquier PC sin saber la clave de administrador**
  https://www.redeszone.net/tutoriales/seguridad/que-es-ataque-pass-the-hash-protegerse/
- **Packages and Binaries**
  https://www.kali.org/tools/impacket/
- **The Hackers Labs**
  https://thehackerslabs.com
- **Uso de la utilidad smbclient para acceder a un recurso compartido SMB**
  https://docs.redhat.com/es/documentation/red_hat_enterprise_linux/8/html/deploying_different_types_of_servers/assembly_using-the-smbclient-utility-to-access-an-smb-share_assembly_using-samba-as-a-server

FUENTES DE VÍDEO

- **Explotación de vulnerabilidades en sistemas Windows obsoletos.**
  https://vimeo.com/1015679494?share=copy
- **Active Directory.**
  https://vimeo.com/1012709192?share=copy#t=0
- **Enumeración básica del entorno AD.**
  https://vimeo.com/1015679561?share=copy
- **Enumeración de usuarios de un dominio.**
  https://vimeo.com/1015679626?share=copy#t=0
- **Cómo efectuar un ataque ASREProast.**
  https://vimeo.com/1015686437?share=copy
- **Enumeración de recursos compartidos desde Kali Linux.**
  https://vimeo.com/1016002463?share=copy#t=0
- **Uso básico de Impacket y pass-the-hash**
  https://vimeo.com/1016008238?share=copy#t=0

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

PREGUNTAS FRECUENTES

- **¿Dónde se utiliza un entorno de Active Directory?**
  Un entorno de Active Directory es ampliamente utilizado en la actualidad en entornos empresariales debido a su capacidad para gestionar de manera eficiente y centralizada los recursos de una red. Diseñado por Microsoft, Active Directory (AD) permite a las organizaciones manejar y organizar sus recursos informáticos, como usuarios, equipos y grupos, de forma estructurada. Al proporcionar una única plataforma para la administración de identidades y políticas de seguridad, Active Directory simplifica la administración de redes complejas y facilita el control de acceso a recursos críticos.

- **¿Es lo mismo un sistema Windows que Active Directory?**
  No, un sistema Windows y Active Directory no son lo mismo, aunque están estrechamente relacionados.

  Por un lado, un sistema Windows se refiere al sistema operativo desarrollado por Microsoft que puede instalarse en computadoras personales, servidores y otros dispositivos. Windows proporciona una interfaz gráfica y una serie de herramientas y servicios para la gestión del sistema y la realización de tareas diarias.

  Por otro lado, Active Directory es un servicio de directorio desarrollado por Microsoft que se integra con Windows Server. Active Directory se utiliza para gestionar y organizar recursos en una red de Windows, como usuarios, grupos, ordenadores y políticas de seguridad. Su propósito principal es facilitar la administración centralizada de los recursos y la implementación de políticas de seguridad en un entorno de red.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

GLOSARIO

A

- **Active Directory (AD)**
  Sistema de gestión de identidades y acceso desarrollado por Microsoft que proporciona servicios de directorio en una red de Windows, facilitando la administración centralizada de usuarios, equipos, grupos y políticas de seguridad.

- **AS-REP Roasting o ASREPRoast**
  Técnica de ataque en Active Directory que explota cuentas de usuario configuradas para no requerir preautenticación Kerberos. Las personas atacantes solicitan tickets de autenticación cifrados con la contraseña del usuario, permitiendo el crackeo *offline* de contraseñas débiles.

D

- **Dominio**
  Unidad organizativa en una red de Active Directory que agrupa recursos y usuarios bajo un mismo conjunto de políticas de seguridad y administración. También se refiere al nombre que identifica un sitio web en Internet.

H

- **Hash**
  Valor alfanumérico generado mediante una función hash a partir de datos de entrada. Se utiliza en criptografía para verificar la integridad de los datos y almacenar contraseñas de manera segura.

J

- **John the Ripper**
  Herramienta de crackeo de contraseñas de código abierto que admite múltiples algoritmos de hash. Utiliza técnicas de fuerza bruta y ataques de diccionario para descifrar contraseñas a partir de hashes.

R

- **Recurso compartido**
  Carpeta o archivo en una red configurado para ser accesible por otros usuarios o sistemas a través del protocolo SMB. Permite compartir datos y recursos entre diferentes máquinas en la red.

S

- **SMB**
  Protocolo de red que permite el intercambio de archivos, impresoras y otros recursos entre sistemas en una red local.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

- **SMBClient**
  Componente de la suite Samba que permite interactuar con recursos compartidos mediante el protocolo SMB. Se utiliza para conectarse a recursos en red, listar archivos y gestionar contenidos.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

IDEASPROPIAS
editorial